

Data Protection Impact Assessment

Biometric age & identity verification — GDPR Art. 35

INTERNAL ACCOUNTABILITY DOCUMENT — draft dated 2026-08-31. This DPIA describes and assesses a processing activity that is already implemented and active. It is maintained for accountability under GDPR Art. 5(2) and produced to the supervisory authority on request. Not for public distribution. Authoritative source: the versioned document in the company repository; this PDF is a rendered copy.

0. Document control

Field	Value
Controller	Shareme Technologies OÜ · Registry 17444422 · Lõõtsa tn 5, 11415 Tallinn, Estonia · contact@sharemechat.com
Processor	Didit — single identity & age verification provider (ADR-035)
DPO / owner	Alain Garmendia (Director). Formal DPO designation to be assessed by volume.
Version	1.0 (draft) · 2026-08-31 · reviewed annually or on vendor/purpose change

1. Why this DPIA is required

Under GDPR Art. 35 a DPIA is required where processing is likely to result in a high risk. Two independent triggers apply here:

- **Large-scale special-category data (Art. 9):** biometric data used to estimate/verify a person's age.
- **Systematic automated evaluation:** automated age estimation that conditions access to the service.

The processing sits within the adult/streaming classification (ADR-028), which requires consumer age verification under the regulation of the target markets (UK Online Safety Act / Ofcom 2025, EU DSA art. 28, US post *FSC v. Paxton*) and under card-network rules (Mastercard AN 5196, Visa Rule ID 0003356).

2. Description of the processing

2.1 Nature — two flows, both operated by Didit

- **Client — age estimation:** facial age estimation (Didit “Age Estimation” workflow), with a document-based check as a fallback where estimation is inconclusive.
- **Model — full identity:** government document + selfie with liveness + face match + device/IP analysis, before onboarding and any live session.

2.2 Scope of data

Data	Processed by	Location
Facial image, document, liveness signals (raw biometrics)	Didit (processor)	Didit infrastructure — not in SharemeChat
Decision outcome	SharemeChat	users.client_kyc_status, verification_status
Estimated age (number)	SharemeChat	users.client_kyc_estimated_age
Decision timestamp	SharemeChat	users.client_kyc_decided_at

Minimisation (implemented in code): SharemeChat does not store raw biometrics. The internal KYC session DTO explicitly excludes biometric data and the provider's raw decision reason. The platform retains only the verdict and the estimated age; the biometric material stays with the processor.

2.4 Purposes

- Prevent minors from accessing adult content (protection of minors).
- Verify identity and adult age of content providers (2257 / card-network rules / anti-fraud).
- Fraud and account-abuse prevention.

Not used for advertising, commercial profiling, or disclosure for marketing.

3. Necessity and proportionality

3.1 Lawful basis

- **Special category (Art. 9):** explicit consent Art. 9(2)(a), obtained before the flow; reinforced by Art. 9(2)(g) (substantial public interest: protection of minors) where national law enables it.
- **Base personal data (Art. 6):** 6(1)(c) legal obligation (age verification required by applicable regulation) and 6(1)(b) necessity for the contracted service.

Consent is freely given (an 18+ service can be declined), informed (privacy policy + in-flow notice) and specific (limited to age/identity verification).

3.2 Principles

- **Purpose limitation:** data used only for age/identity verification.
- **Minimisation:** only decision + estimated age retained; raw biometrics stay with the processor.
- **Accuracy:** two layers (estimation + document fallback); re-verification on reasonable indication.
- **Storage limitation:** provider verification records ≥ 7 years after last activity (2257 / card rules); processor retention capped (target 6 months, not “unlimited”).
- **Integrity & confidentiality:** encryption in transit, access control, signed webhooks (HMAC + anti-replay), separation of biometrics (processor) from verdict (platform).

3.3 Processor (Didit)

Formalise the DPA + TOMs; confirm data location and international transfers (SCC if outside the EEA); configure capped retention in the provider console.

4–5. Risk assessment and measures

#	Risk to the data subject	Measures	Residual
R1	Unauthorised access to raw biometrics	Not stored on the platform; held by processor under DPA/TOMs; encrypted	Low
R2	False rejection of an adult	Document fallback; re-verification; human review	Low–Med
R3	Function creep	Purpose limitation; only decision+age retained; no ad use	Low
R4	Processor breach	Specialised vendor; DPA/TOMs; 72h breach notice; minimisation	Low–Med
R5	Int'l transfer without safeguard	Confirm location in DPA; SCC or equivalent	Low*
R6	Processing a minor's data	The very purpose is to detect and exclude minors; deletion + block on detection	Low
R7	Excessive retention	Capped retention at processor; provider limited to legal obligation	Low

* after formalising the DPA with Didit.

6. Conclusion and pending actions

With structural minimisation (biometrics never touch the platform), explicit consent, and purpose/storage limitation, the **residual risk is low** and proportionate to protecting minors and meeting applicable regulation. The processing is considered **necessary and proportionate**.

Pending to close (non-technical):

- Formalise the **DPA + TOMs** with Didit; confirm location / transfers.
- Confirm the **retention period** configured in the Didit console (target 6 months).
- **Enrich the Privacy Policy** with the biometric-flow detail and the processor.
- Assess a **formal DPO designation** by volume.
- External legal validation, at the operator's discretion.